

D3-FI 全面安全复检报告(v3)

当前代码全量复核 · 新增金库资金管理流深度审计 · 线上系统实测

项目:D3-FI-UI(Supabase Edge Functions/Deno + BSC 合约 + React) · 分支: `main` (origin 同步)
认证:Reown AppKit + SIWE(EIP-4361) · 结算币:测试/水龙头币(fake USDT) · 阶段:未上线
自 v2 变更:新增「资金管理」金库转账流、两阶段结算完善、迁移重编号(042-049 无冲突)、R-1...R-11 修复

判定:CONDITIONAL — 核心资金安全经实测达标;新金库转账流需应用层加固后方可承载真实资金

163

安全测试全绿

0

anon 可达资金表(实测)

8/11

R 系列已修复(3 项按设计延后)

6

新金库流待加固项(T-A...T-J)

一、结论摘要

核心资金安全姿态强,且经线上实测:SIWE 认证(登录 200、无令牌资金路由 401 失败关闭)、全库 RLS(anon 授权实测为 0)、原子借贷记、闪兑五重护栏、限额熔断、价格护栏、充值/奖励幂等——全部完好;上次 R-1...R-11 中 8 项已修复并推送。

本次重点新发现(必须知悉):你新增的「资金管理 / 金库转账」流(`fundManagement.ts` + 迁移 047 + 后台页)是最高风险的金库出账路径,其签名层依赖 Turnkey 2/3 root-quorum(设计正确),但应用层薄弱:无独立金库权限、无 maker-checker、无金额/白名单/限额、无幂等,且存在一条 `dev_hd` 内联签名+即时广播的单人掏空旁路(配置相关)。详见第四节 T-A...T-J。

综合判定维持 CONDITIONAL:测试期(水龙头币)安全;承载真实资金前须完成金库流加固(T 系列)+ 既有部署清单。

二、经实测验证的核心防护(CLOSED)

域	结论	证据(当前代码 / 线上实测)
SIWE 认证	强·已验证	nonce 原子单次+域名服务端白名单+HS256 常量时间;线上:登录 200、无令牌资金路由 401
数据库锁定	已验证	14 原表 + siwe_nonces/告警/风控/审批/treasury_transfer_requests 全 RLS;线上 anon 授权=0
原子借贷记	完好	pending_d3_yield/ud3_balance/pending_ud3 全经原子 RPC;两阶段结算无读写改写
闪兑 / 质押 / 充值	完好	请求时原子扣减+在途唯一+失败回补+仅未广播才退款+≥12 确认;充值入口守卫+链上校验+原子跃迁
限额/熔断/价格	完好	扣减前 assertWithdrawAllowed(单笔/日/时/偿付率);价格失效即拒付
后台/推荐/迁移	已验证	admin RLS 递归修复正确;admin_users 授权仍受 RLS 约束仅可读自身行;推荐防自荐/环路;迁移无编号冲突

三、R-1...R-11 处置状态(v2 发现)

ID	发现	状态
R-1	迁移编号重复(038/042)	已修复(重编号 048/049,无冲突)
R-3	审批越权(subsidies.write 可解熔断)	已修复(按 action 校验权限)
R-4	陈旧 deploy-pages.yml 第二源	已删除
R-5	/auth/* 无限流(DoS)	已修复(宽松限流+nonce 清理)
R-6	pending_ud3 缺 CHECK≥0	已修复(迁移 046)
R-7	结算出错仍标记 settled	已修复(成功才标记)
R-9	.env.example 缺 SIWE/CRON	已补
R-11	推荐链自荐守卫 / 死代码	已加自荐守卫
R-2	水龙头币作主网结算资产	按设计(测试期);上线前钉真实 USDT
R-8	会话 7 天无吊销/jti	延后(避免测试期动热认证路径)
R-10	推荐合约角色在热 EOA	你的链上操作(转多签)

四、【本次新发现】金库资金管理 / 转账流(T 系列)

架构:后台管理员 → submitTreasuryTransfer 构造 BSC 交易(BNB/USDT)→ 提交 Turnkey SIGN_TRANSACTION → 因金库钱包(应)受 2/3 root-quorum 保护而返回 CONSENSUS_NEEDED ,由 3 名 root 中 2 名在 Turnkey 面板批准后广播。签名层设计正确,但应用层缺乏独立控制,"非单人可掏空"完全依赖链下 Turnkey 配置,代码不强制。

ID	发现	严重度	证据 / 修复
T-C	dev_hd 内联签名+即时广播绕过全部 consensus:若金库钱包被 dev 方式 provision 或 2/3 阈值未提升,单一 members.write 管理员一次调用即可把金库全额转到任意地址	Critical(配置相关)	turnkey.ts:549 、 fundManagement.ts:155 。修复:生产强制拒绝金库 dev_hd ;代码断言/校验 Turnkey 阈值≥2
T-A	金库出账仅由低阶共享权限 members.write 门控(与普通会员管理/生成充值地址同权);无专用财务/金库权限;superadmin 全绕过	High	admin/index.ts:1066,1101 。修复:新增专用 treasury/finance 权限或仅 superadmin
T-B	金库转账无应用层 maker-checker:同一管理员可 propose 又 broadcast; assertDifferentApprover 未接入金库流(其余高危面都有)	High	admin/index.ts 未走 createApproval 。修复:propose→broadcast 走双人审批
T-D	无金额上限 / 收款白名单 / 每日限额;且 turnkey-setup-policies.ts:72 注释谎称"应用层已有单笔/每日限额"——实际不存在	Med-High	fundManagement.ts:118 。修复:服务端加最大额+白名单+日限;删除误导注释
T-E	无每笔幂等键:两次相同 propose → 两条记录 → 两个 Turnkey 活动 → 若都被批准则两笔链上转账	Med	迁移 047 无幂等键。修复:加 request idempotency key 唯一约束
T-J	Turnkey 策略兜底 DENY(condition:'true') 与"金库应 fall-through 到 root-quorum"的 DSL 语义未在仓内验证	Med(运维/正确性)	链上实测确认金库转账确实到达 CONSENSUS_NEEDED 而非被直接拒
—	正面: to / amount 编入 Turnkey 签名载荷、广播不重读 DB(无 TOCTOU);047 有 amount>0/asset/status CHECK + RLS anon 撤销;propose/broadcast 均写审计	GOOD	—

净新增风险:一条金库出账路径,唯一实质保障是链下 Turnkey 2/3 consensus;应用层无 maker-checker、低阶共享权限、无额度/白名单/幂等,并有 dev_hd 单人掏空旁路。建议在承载真实资金前按上表修复,并链上核实金库确为真实 2/3 Turnkey 钱包。

五、线上系统实测验证

```
登录      POST /union/auth/nonce      -> 200      (SIWE 正常)
资金路由  POST /treasury/partner/sd3-stake -> 401 Session token required(失败关闭)
线上库    anon schema 表授权 = 0 ; treasury_transfer_requests RLS = on
线上库    admin_users 仅 authenticated 授权(RLS 约束仅可读自身行)
迁移      042-049 无编号冲突 ; 安全回归测试 20 文件 / 163 全绿
```

六、上线前检查清单(承载真实资金)

- T-C 生产强制拒绝金库 dev_hd ;代码校验 Turnkey root quorum≥2(不假设手动步骤已做)
- T-A/T-B 金库转账加专用权限 + propose→broadcast 双人 maker-checker
- T-D/T-E 服务端金额上限+收款白名单+日限;每笔幂等键;删误导注释;T-J 链上验证 consensus 语义
- R-2 钉真实 USDT、移除 ALLOW_MAINNET_FAUCET_TOKEN ;R-8 会话 jti/吊销;R-10 推荐合约角色转多签
- 凭证隔离:金库/cosigner 密钥移出边缘环境;部署边缘函数 npm run supabase:deploy ; npm run turnkey:policies
- 上线前跑 npm run security:preflight 要求 PASS;配置告警推送 SECURITY_*

已完成 / 已验证

- ✓ SIWE 认证 + 全库 RLS + anon 授权清零(线上实测)· 原子账本 / 闪兑护栏 / 限额熔断 / 价格护栏 / 幂等
- ✓ R-1/3/4/5/6/7/9/11 修复 · 监控引擎+熔断开关+安全中心页+preflight · 迁移无冲突